

Clase 216 — Contención, erradicación y recuperación

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *NIST SP 800-61 Rev. 2* y SANS PICERL 

Duración estimada: **110 min** · Nivel: **Intermedio**

Objetivo

Dominar las tres fases centrales de la respuesta: **contener** la amenaza sin destruir evidencia, **erradicar** la causa raíz por completo y **recuperar** la operación con confianza. Al terminar sabrás decidir entre aislar u observar, eliminar toda la persistencia y validar que el atacante realmente se fue.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Elegir** la estrategia de contención adecuada (aislar vs. observar).
2. **Preservar** evidencia durante la contención.
3. **Erradicar** malware y persistencia de forma completa.
4. **Recuperar** sistemas con monitoreo reforzado.
5. **Validar** que la amenaza fue eliminada antes de cerrar.

Temas

#	Tema	Por qué importa
1	Contención corto vs. largo plazo	Rapidez vs. estabilidad
2	Aislar vs. observar	Trade-off inteligencia/riesgo
3	Preservar evidencia al contener	No romper la forense
4	Erradicación de persistencia	El atacante no debe volver
5	Reconstrucción vs. limpieza	Confianza en el sistema
6	Rotación de credenciales	Cerrar el acceso robado
7	Recuperación monitorizada	Detectar reinfección
8	Validación de erradicación	Criterio para cerrar

Definiciones y características

- **Contención a corto plazo:** acción inmediata para frenar la propagación (aislar un host).
Característica: rápida, a veces temporal.
- **Contención a largo plazo:** medida estable mientras se erradica (segmentar red, regla de firewall).
Característica: mantiene operación sin dar terreno.

- **Aislar vs. observar:** cortar al atacante ya, o vigilarlo para ganar inteligencia. Característica: observar arriesga más daño pero revela alcance.
- **Erradicación:** eliminar la causa (malware, cuentas, vulnerabilidad, persistencia). Característica: incompleta si queda un solo mecanismo.
- **Persistencia:** mecanismos del atacante para sobrevivir a reinicios (servicios, tareas, claves). Característica: hay que enumerarlos todos.
- **Reconstrucción (rebuild):** reinstalar desde cero. Característica: la única garantía plena tras un compromiso profundo.
- **Validación:** confirmar que no hay actividad maliciosa residual. Característica: monitoreo reforzado por un periodo.

Herramientas y preparación

- **Contención:** reglas de firewall/EDR para aislar, VLAN de cuarentena.
- **Erradicación:** EDR (aislar y remediar), `autoruns` (persistencia Windows), revisión de cron/systemd (Linux).
- **Credenciales:** gestor de secretos, rotación de claves, revocación de sesiones/tokens.
- **Ejercicio aplicado:** diseño y práctica en laboratorio propio.

Laboratorio guiado

Sobre una VM de laboratorio propia previamente "comprometida" por ti.

1. **Contén** el host aislándolo por red sin apagarlo (preservas RAM y estado): - EDR: acción "aislar"; o regla de firewall que solo permita la IP del analista.
2. Antes de erradicar, **captura evidencia:** volcado de RAM (clase 207) e imagen de disco (clase 203).
3. **Enumera la persistencia** en Windows con Autoruns:

```
powershell autorunsc.exe -a * -c > autoruns.csv
```

Revisa servicios, tareas programadas, claves Run, y WMI. 4. En Linux, revisa cron, systemd y perfiles de shell (clase 206) para hallar toda la persistencia. 5. **Erradica:** elimina cada mecanismo identificado y el malware. Si el compromiso fue profundo (root/SYSTEM), planifica **reconstrucción desde cero**. 6. **Rota credenciales:** cambia contraseñas, revoca tokens/sesiones y claves API que el atacante pudo ver. 7. **Recupera** el sistema con monitoreo reforzado: EDR en alerta, logging aumentado, y una regla que avise si reaparecen los IOCs. 8. **Valida:** define un periodo de observación y los criterios ("cero IOCs, cero conexiones al C2, cero reintentos de la persistencia") para cerrar.

Ejercicios

1. Decide para tres escenarios si aislar u observar, y justifícalo.
2. Enumera cinco mecanismos de persistencia en Windows.
3. Explica por qué a veces la única opción es reconstruir.
4. Diseña un plan de rotación de credenciales tras un compromiso.
5. Define los criterios de validación de erradicación.
6. Explica cómo contener sin perder la memoria del equipo.

Reto verificable

En una VM comprometida por ti, ejecuta las tres fases: contén preservando evidencia, erradica toda la persistencia (demuestra que la enumeraste completa) y valida la erradicación con criterios explícitos.

Criterio de aceptación: documentas (a) cómo aislaste sin perder evidencia, (b) la lista completa de mecanismos de persistencia hallados y eliminados, (c) la rotación de credenciales, y (d) los criterios cumplidos que te permiten declarar erradicado el incidente.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El malware reaparece tras limpiar	Quedó persistencia sin eliminar. Enumera TODA con Autoruns/cron/systemd.
Perdiste la RAM al contener	Apagaste el equipo. Aísla por red, no por apagado.
El atacante vuelve con la misma clave	No rotaste credenciales. Cámbialas y revoca sesiones.
Limpiaste pero no confías en el host	Compromiso profundo. Reconstruye desde cero.
Cerraste demasiado pronto	Sin periodo de validación. Monitorea antes de declarar resuelto.

Preguntas frecuentes

 **¿Aislar u observar?** Aísla si el riesgo de daño es alto; observa solo si necesitas inteligencia y puedes contener el daño. Ante la duda, aísla.

 **¿Limpiar o reconstruir?** Ante compromiso con privilegios altos o rootkits, reconstruye: es la única garantía de que no queda nada.

 **¿Cuándo roto credenciales?** Siempre que el atacante haya podido acceder a ellas: contraseñas, tokens, claves API, secretos de servicio.

 **¿Cómo sé que erradiqué de verdad?** Con monitoreo reforzado durante un periodo y criterios objetivos: cero IOCs activos, cero conexiones al C2, cero reintentos de persistencia.

Referencias

- NIST SP 800-61 Rev. 2: <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- Sysinternals Autoruns: <https://learn.microsoft.com/sysinternals/downloads/autoruns>
- MITRE ATT&CK — Persistence (TA0003): <https://attack.mitre.org/tactics/TA0003/>
- SANS — Incident Handler's Handbook: <https://www.sans.org/white-papers/33901/>

Siguiente clase

Clase 217 - Analisis de causa raiz